

BEST PRACTICE REPORT

The Architect's Guide To Quantum Security

Sandy Carielli, Heidi Shey, Andras Cser, and three contributors

IN THIS RESEARCH

Summary

The Quantum Future Is Here: Governments Are Leading The Way

The Goal Is Cryptoagility Across Your Security Tech Stack For Quantum Security

Arrange Architectural Building Blocks According To Three Patterns

Choose The Right Architectural Patterns For Your Environment

Proxy: Overlay On Existing Components And Future-Proof With Cryptographic Agility

Upgrade: Replace Existing Components With Versions Supporting New Algorithms

Quantum Key Distribution: Exchange Keys Over Short Distances Without PQ Algorithms

Provide Guidance And Set Expectations With Key Stakeholders

Summary

Advances in quantum computing have pushed quantum security to the forefront, but the migration to quantum-safe cryptographic solutions is not straightforward. Architects and security leaders must help their organization define a prioritized migration path and select the proper building blocks to address their system architecture. Using patterns (like proxies and upgrades), architects can show stakeholders how all the technical elements work together. They can also help the business improve prioritization and future-proof cryptographic changes.

The Quantum Future Is Here: Governments Are Leading The Way

While we cannot determine the day (aka Q-Day) when commercially available quantum computers will be able to break asymmetric cryptography and algorithms, Forrester's best estimate is that this will happen in 10 years. But it could also happen in five or 20 years. Currently, many governments have established a deadline of 2035 for full migration to use of postquantum cryptography (PQC). The Australian Signals Directorate guidelines for cryptography are the most aggressive, with 2030 as the deadline. This report provides guidance for security architects responsible for enabling their organization's migration to PQC and building out their internal systems to be quantum safe. Now is the time to begin planning and start your approach to architecture for PQC because:

- **Q-Day will bring profound changes to every area of security.** It forces an overhaul of the underlying plumbing of the security technology stack across an organization, as the current foundational building block (cryptography) used for protecting your data will be rendered useless. The security domains that will experience the biggest effects include certificate and key management, data encryption, electronic signatures (such as in code security, email security, and non-repudiation solutions), authentication (human, machine, IoT, mobile devices, network access control), network infrastructure, and secure communications.
- **A full migration to use of postquantum cryptography is an enormous undertaking.** An optimistic timeline is three to five years, with many dependencies that can help or hinder progress. Recognizing the urgency and impact, governments have issued guidance and deadlines for migration. Industry-specific entities have issued guidance, such as the European Telecommunications Standards Institute (ETSI) [framework](#) for quantum-safe migrations, the FS-ISAC [framework](#) for replacing an insecure algorithm, and the Bank of Israel's [Directive 364](#). Regulatory requirements and standards such as PCI-DSS v4.0.1 and EU DORA highlight the need to monitor developments and vulnerabilities in cryptography, as well as the need for cryptoagility.
- **Your target architecture is to upgrade your entire security stack to ensure cryptoagility.** This enables changing cryptographic algorithms in applications, infrastructure, software, and hardware products as encryption threats, requirements, and standards change. It is a way to future-proof and harden your security infrastructure for the future to protect data. Business partners will view

your organization as a third-party risk if you do not; the lack of cryptoagility may violate contractual obligations for data handling and security or torpedo a potential partnership. Regulators will also begin to demand cryptoagility for an increasing number of compliance requirements.

The Goal Is Cryptoagility Across Your Security Tech Stack For Quantum Security

There is no guarantee that today's finalized and future-approved PQC algorithms will remain suitable for protecting data over time. There is also no single PQC algorithm to rule them all; there are different ones better suited for different purposes. Cryptoagility will be essential as we look to the future of quantum security. To get started today:

- **Assess your existing deployed technologies.** Query your technology vendors about their plans for PQC migration and cryptoagility for their products. Don't use the results as a reason to rush to replace a vendor yet. Use them to inform your plans, identify key technology partners, and refine your migration timeline. Expect vendors for which early use of PQC will have the strongest impact to have a more well-formed plan for migration, as well as use of PQC in their products. This includes those in areas such as certificate and key management, data encryption, digital signature, network security, mobile device management, machine and IoT identity management, and cloud infrastructure platforms. We anticipate that PQC-related product announcements will grow steadily through 2025 and 2026. For near-term new investments and renewals, assess their capabilities today to help you on your migration effort as a part of RFPs, such as with data security platforms from IBM and Thales, which already offer functionality for cryptographic discovery and inventory.
- **Investigate how specialized quantum security startups can help with cryptoagility.** Many currently address multiple different use cases, from PQ key exchange to cryptographic algorithm change management (cryptoagility). Example vendors include Crypto4A, Cryptomathic, InfoSec Global, ISARA, PQShield, SandboxAQ, QuSecure, and Quantum Xchange. We expect considerable venture capital investment in quantum security firms in the next three to 10 years, as well as established security companies conducting M&As of quantum security startups.

Arrange Architectural Building Blocks According To Three Patterns

Architects migrating applications and systems to quantum security must balance short-term fixes with longer-term strategic plans, but this creates distractions and leads to debates around time and cost. For example, an engineer might replace an application that uses RSA encryption with a new application version that has implemented one of the approved postquantum algorithms, which could meet the immediate requirement. However, architects looking to future-proof their environment against ongoing cryptographic changes might want to implement cryptographic agility systems that add short-term cost but make upgrading simpler in the long term — the architect would make a configuration change in the cryptoagility tool rather than spending time upgrading systems and software directly. When considering the various quantum security implementation architectures, we identified the common components of quantum security architectural building blocks, which we have split into primary building blocks and dependent building blocks (see Figure 1).

- **Primary building blocks of quantum security include cryptographic libraries and proxies.** Organizations apply these building blocks to their homegrown applications and systems to add quantum security. New cryptographic libraries with approved postquantum algorithm implementations will replace older libraries, and members of the development and security team will be responsible for replacing those libraries in applications. Meaningfully phasing means two- to three-month-

long overlapping sprints not taking longer than a total of 12 to 24 months. Cryptographic agility components like proxies will layer on existing servers or services to add postquantum support, and orchestration layers will help manage the proxies throughout the environment. Quantum key distribution transceivers and hardware are options for limited high-end point-to-point or hub-and-spoke scenarios.

- **Dependent building blocks require vendor and partner support.** An organization doesn't develop these building blocks but does purchase, deploy, or integrate with them. These building blocks include third-party applications, open source and commercial software libraries, and network components, like gateways and routers, that vendors and partners will need to upgrade to support postquantum algorithms. Organizations will also need a plan to replace endpoints like employee laptops and mobile devices with new systems that embed appropriate postquantum support. If they hope to streamline their postquantum migration, security and infrastructure leaders must also engage with public key infrastructure (PKI) vendors and data security service providers. For all dependent building blocks, organizations will need to collaborate with vendors to understand migration plans and timelines and ensure that implementations are compatible with the rest of their organization's infrastructure.

FIGURE 1

Some Architecture Building Blocks Of Quantum-Secure Implementations

Primary integrated building blocks



Organizations that build software and firmware products that use public key cryptography will need to upgrade their existing **cryptographic libraries** to versions that contain approved implementations of postquantum algorithms.



Proxies wrap around existing applications and devices and conduct all cryptographic work at the proxy layer. Proxies let developers move away from hard-coded algorithm choices and help future-proof applications against changes to cryptographic standards. Proxies may be added to every system or added to the systems that serve as entry points to different environments.



Cryptographic agility solutions combine proxies with an **orchestration layer** that discovers, manages, and configures the cryptographic algorithms for the proxies and associated systems. Security leaders monitor and manage cryptographic agility via the orchestration layer.



For close-proximity point-to-point scenarios where quantum key distribution (QKD) is an option, organizations will need to deploy dedicated connections like **fiber-optic cables** and work with QKD vendors to add **QKD hardware and transceivers** at each point.

Dependent building blocks



Organizations must upgrade **third-party software** — whether components built into an organization's own application or a purchased piece of software — that uses public key cryptography. The providers that own these software components and products are responsible for upgrading them — work with these third-party providers to understand plans and timelines.



Any proxies, routers, gateways, or other **network devices** that transmit traffic securely over the internet must ultimately support postquantum algorithms. Network device vendors are responsible for upgrading these devices — work with vendors to understand plans and timelines.



Endpoints and devices, including laptops, mobile devices, and IoT devices, must have updated hardware, firmware, and software that supports postquantum algorithms. The device manufacturers are responsible for upgrading these devices — work with those vendors to understand plans and timelines.



While it falls under the category of third-party software or devices, **cryptographic infrastructure**, such as certificate authorities and hardware security modules (HSMs), deserves special attention, since these components play a crucial role in enabling TLS. Work with your CA, HSM vendor, and related providers to start planning postquantum migration.

© Forrester Research, Inc. Unauthorized reproduction, citation, or distribution prohibited.

Choose The Right Architectural Patterns For Your Environment

The primary and dependent building blocks are the common components that architects will leverage to construct a quantum-safe environment — these can be arranged into a few different patterns. To make the right trade-offs, focus on the patterns that best support your business cases and technology environment. Remember that these patterns are not mutually exclusive — an architect can apply different patterns to different components in the same environment.

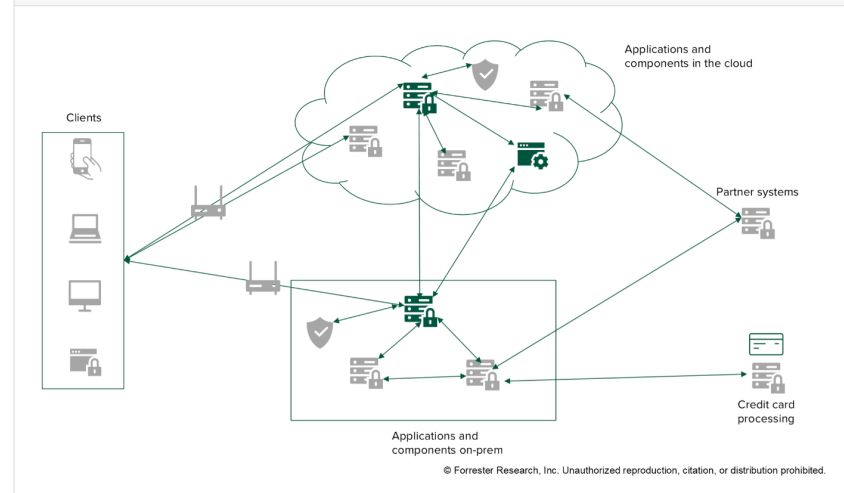
Proxy: Overlay On Existing Components And Future-Proof With Cryptographic Agility

In a proxy-based approach, the organization works with a cryptographic agility provider

and adds a proxy layer to an existing application, system, or service (see Figure 2). All of the system's cryptographic activities occur through the proxy, so the system always supports the latest approved cryptographic algorithms without needing to change code. The proxies connect to an orchestration layer where security leaders can manage all proxies and systems through a single control plane — the orchestration layer may be deployed in the cloud or on-prem, depending on what the cryptographic agility provider offers. Vendors like InfoSec Global, QuSecure, and SandboxAQ provide cryptographic agility solutions.

FIGURE 2

Replace Static Encryption Components With Proxy-Based Options That Enable Agility

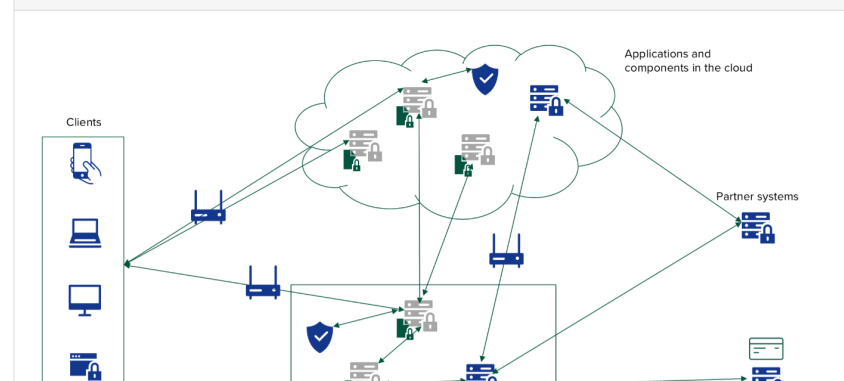


Upgrade: Replace Existing Components With Versions Supporting New Algorithms

The upgrade approach is a matter of replacing software, devices, and third-party dependencies with versions that have been implemented or support postquantum algorithms (see Figure 3). For software developed in-house, this likely means upgrading to a new cryptographic library with approved implementations of approved algorithms. The [Post-Quantum Cryptography Alliance \(PQCA\)](#), launched by the Linux Foundation, is a good reference source for the available libraries. Look for opportunities to enable agility through your choice of and implementation of cryptographic libraries. For third-party software and devices — dependent building blocks — this means upgrading to new versions that support the latest algorithms — it also means working with these providers to understand their timelines and how they plan to enable agility going forward. As part of the upgrade, remember to pay attention to supporting components like certificates and certificate management in support of TLS, gateways, routers, and other components that handle internet traffic.

FIGURE 3

Upgrade Existing Systems To Postquantum-Friendly Versions



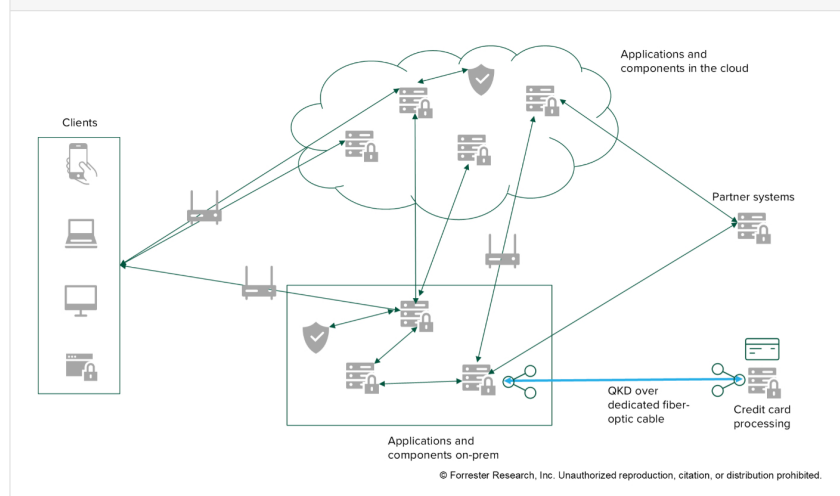
Quantum Key Distribution: Exchange Keys Over Short Distances Without PQ Algorithms

In quantum key distribution (QKD), two parties transmit photons back and forth over fiber-optic cables, and the random path of the photon sequence generates a secret key. This eliminates the need for postquantum algorithms that would otherwise handle key exchange. In a QKD environment, changes to PQ algorithms would not require any changes to the QKD system, leading to greater agility. Today, QKD adoption is stymied by high costs, lack of standardization, and limitations in distance — e.g., how far the photons can travel stably over the cable. Therefore, QKD is a niche pattern most appropriate to highly sensitive point-to-point or hub-and-spoke transactions over a short distance, such as in the tens of miles (see Figure 4). For example, a payment processor might opt for quantum key distribution to pass credit card transactions on the backend between nearby systems.

Assume that organizations implementing QKD only do so for certain steps of the data journey and that earlier parts of the transaction, like client-server interactions, will use one of the other patterns. Vendors like IBM, Palo Alto Networks, Quintessence Labs, and Toshiba offer different levels of quantum key distribution.

FIGURE 4

Use QKD For Highly Sensitive Transactions In Point-To-Point Or Hub-And-Spoke Scenarios



Provide Guidance And Set Expectations With Key Stakeholders

As security leaders and security architects take the lead on strategy and technical implementation approaches for quantum security, they don’t act alone. They must also align with key internal stakeholders like compliance and risk management, account for these stakeholder concerns, and work together to address challenges with PQC migration and cryptoagility:

- Compliance needs assurance, but the reality is not straightforward.** The compliance team’s expectations for meeting compliance may not align with what is feasible or require additional steps to achieve. For example, there may be situations where legacy systems cannot swap out the encryption algorithm. If PCI-DSS compliance is a concern, the organization’s use of a proxy-based approach may be considered a [customized approach](#) with documentation. In another example, your organization may need to ensure it is using a FIPS validated encryption module for compliance. However, a FIPS validation backlog may stretch

encryption means for compliance. However, if the transition seems too costly, then, leaving your organization with the conundrum of implementing PQC today but being out of compliance or using non-PQC (and facing the associated security risks) and being in compliance.

- **Risk management needs security input to manage third-party risk in this migration.** There are a multitude of dependencies in your PQC migration efforts and road to cryptoagility. Working with your technology suppliers within your environment is one of them. Their product roadmaps and timelines impact your migration plans and roadmap. Build questions into RFPs to ask technology vendors about their plans for PQC migration and cryptoagility, both for their technology infrastructure as a business as well as in product development. Query your existing technology suppliers, as well, to assess their current state and anticipated plans, prioritizing outreach and potential design partnerships based on the criticality of their use within your environment. Data discovery, risk assessment, and prioritization in most cases should happen in 12 to 18 months, overlapped by 12- to 24-month-long encryption algorithm migration activities.

Governance: Verified Sources, Sanctioned Algorithms, And Performance Matter

Quantum security governance is tricky today: Because the area is still in constant flux and uncertainties abound on the timeline of quantum supremacy (when quantum computers can break asymmetrical encryption), organizations are shooting at an elusive and moving target. With quantum chips just appearing on the product palette of platform vendors (such as Microsoft), buyer organizations need to refocus on QS governance aspects, and they should specifically:

- **Ensure that quantum security software sources are easily verifiable and reputable.** Quantum security (QS) — especially PQC — represents a crucial pillar of IT security at an organization. It is imperative that security and risk (S&R) professionals get assurances from vendors (software bill of materials [SBOM], cryptographic bill of materials [CBOM], algorithms used, certification status of algorithms used, etc.) on the quality of infrastructure hardware and software and business software PQC components. Whenever possible, QS architects should buy and not build QS and postquantum encryption (PQE).
- **Divide PQC algorithms into sanctioned, tolerated, and prohibited groups.** Because firms need to limit the sprawl and thus the number of PQC algorithms for reasons of cost, security, and testability, they should divide PQC algorithms into sanctioned (supported), tolerated (allowed but unsupported), and prohibited (disallowed and, if seen, to be eliminated) algorithms. Internal development teams using prohibited algorithms can expose the organization to unwanted and/or undiscovered data security vulnerabilities. ZTNA solutions (including Palo Alto Networks) are already offering next-generation firewalls (NGFW) that can detect and classify the network footprint of various PQC algorithms.
- **Balance PQE performance needs with security requirements.** Use of PQC requires adequate performance planning and testing due to: 1) the performance characteristics of the PQC algorithms and 2) the risk of latency when using proxy-based solutions. Relatively little benchmarking data is available today on PQC algorithms' performance. Because of the above, time-critical use cases (payment processing and other, response-time-bound applications), QS architects — at least initially — may have to forego using PQE and use network compartmentalization to maintain performance, and possibly even multiple levels of it.

Supplemental Material

Companies We Interviewed For This Report

We would like to thank the individuals from the following companies who generously

gave their time during the research for this report.

Palo Alto Networks

QuSecure